

## **TOSCANA DIAGNOSTICA S.r.l.**

Sistema di Gestione Integrato

### **QUALIFICAZIONE E VALUTAZIONE DEI FORNITORI**

Area 14 – Operations

| Codice                  | Revisione              | Data                                              | Pagine    |
|-------------------------|------------------------|---------------------------------------------------|-----------|
| <b>TD-SGI-PRO034_01</b> | 01                     | 30/04/2026                                        | 6         |
| Redatto da              | Approvato da           | Classificazione                                   | Stato     |
| Procurement + RSGI      | AD – Francesco Epifani | Distribuito a Procurement +<br>funzioni operative | In vigore |

| Responsabile del Documento | RSGI           | Emissione del Documento |
|----------------------------|----------------|-------------------------|
| Valentina Zezza            | Iacopo Cupelli | Francesco Epifani       |
| 30/04/2026                 | 30/04/2026     | 30/04/2026              |

**Toscana Diagnostica S.r.l.**

Via di Pratignone, 13/4, 50019 Sesto Fiorentino (FI). Tel. e Fax: 055776511. Direttore Sanitario: prof. Gian Luigi Taddei.  
P.IVA e C.F.: 07528130482, REA n. FI-709602 – Capitale Sociale: € 50.000,00 i.v.

## 1. Scopo e ambito (rev 01)

La presente procedura definisce le modalità di qualificazione e valutazione periodica dei fornitori di Toscana Diagnostica S.r.l., in coerenza con i requisiti ISO 9001:2015 §8.4 (Controllo dei processi, prodotti e servizi forniti dall'esterno) e ISO 15189:2022 §6.6 (Servizi forniti dall'esterno). La rev 01 estende la procedura introducendo il concetto di FORNITORE CRITICO (con requisiti di qualifica rinforzati) e formalizzando i criteri di AUDIT periodico dei fornitori critici, in coerenza con ISO/IEC 27001:2022 §A.5.19-A.5.23 e con la Direttiva NIS2 (D.Lgs. 138/2024 art. 24 c. 2 lett. d).

La procedura si applica a tutti i fornitori di beni, servizi, opere intellettuali rilevanti per i processi di TD: fornitori di consumabili e reagenti, di kit IVD, di strumentazione di laboratorio, di servizi ICT, di servizi sanitari esterni, di servizi di facility management, di consulenza professionale.

## 2. Riferimenti

| Riferimento                                  | Ambito                                                                       |
|----------------------------------------------|------------------------------------------------------------------------------|
| ISO 9001:2015 §8.4                           | Controllo dei fornitori                                                      |
| ISO 15189:2022 §6.6                          | Servizi esterni                                                              |
| ISO 14001:2015 §8.1 + §6.1.3                 | Aspetti ambientali — fornitori                                               |
| ISO/IEC 27001:2022 §A.5.19-A.5.23            | Sicurezza fornitori — supply chain                                           |
| D.Lgs. 138/2024 (NIS2) art. 24 c. 2 lett. d) | Sicurezza catena di approvvigionamento ICT                                   |
| Reg. UE 2017/746 (IVDR) artt. 10-13          | Operatore economico — produttore IVD                                         |
| TD-SGI-PRO070 §8                             | Procedura NIS2 — fornitori ICT critici                                       |
| TD-SGI-MOD040 + MOD041 + MOD042              | Moduli operativi qualifica fornitori                                         |
| TD-SGI-MOD182                                | Inventario Fornitori ICT (NIS2)                                              |
| TD-SGI-MOD195                                | Modulo valutazione fornitori service Lab                                     |
| TD-SGI-PRO083                                | Selezione e qualifica laboratori service esterni                             |
| TD-SGI-PRO091                                | Gestione Rifiuti Sanitari Pericolosi (interfaccia con fornitori smaltimento) |

## 3. Classificazione dei fornitori

### 3.1 Categorie

| Categoria                                | Definizione                                                                                                                                                    | Esempi TD                                                                                                                                                       |
|------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------|
| FORNITORE CRITICO (introdotto in rev 01) | Fornitore la cui inadempienza/compromissione genera impatto significativo (operativo, reputazionale, regolatorio, di continuità) sui processi essenziali di TD | LIS/RIS/PACS, datacenter, MSSP/SOC, fornitori IVD high-volume, smaltitore rifiuti pericolosi, conservatore digitale, DPO esterno, Studio Legale per Modello 231 |
| FORNITORE RILEVANTE                      | Fornitore che impatta su processi importanti ma con dipendenza media e sostituibilità in tempi ragionevoli                                                     | Cancelleria specializzata di lab, fornitori di formazione qualificata, manutenzione strumenti non critica                                                       |
| FORNITORE STANDARD                       | Fornitore di beni/servizi commodity, pienamente sostituibile in tempi                                                                                          | Cancelleria generica, materiale d'ufficio, vending                                                                                                              |

brevi

### 3.2 Criteri di criticità (rev 01)

Un fornitore è classificato come CRITICO se ricorre ALMENO UNO dei seguenti elementi:

- (a) eroga servizi essenziali ai processi clinici/operativi di TD (LIS, RIS/PACS, refertazione, conservazione documentale, datacenter, connettività, MSSP);
- (b) tratta dati personali di pazienti come responsabile del trattamento ex art. 28 GDPR — anche solo come accesso tecnico;
- (c) ha accesso privilegiato (admin, root, service account) ai sistemi clinici di TD;
- (d) un'eventuale indisponibilità prolungata (>4 ore per servizi clinici / >24 ore per altri) genera impatto operativo significativo sulla continuità diagnostica;
- (e) la sua compromissione potrebbe innescare una notifica obbligatoria al CSIRT Italia (NIS2) o al Garante (GDPR);
- (f) eroga consulenza specialistica con accesso a informazioni riservate aziendali (es. Studio Legale Maresca, DPO, OdV esterno);
- (g) è produttore o distributore di IVD/dispositivi medici utilizzati nei processi diagnostici (rilevanza IVDR);
- (h) rappresenta una quota di spesa annuale > 5% del totale acquisti TD (criticità economica).

## 4. Procedura di qualifica iniziale

### 4.1 Documentazione richiesta — fornitori CRITICI

| Documento                                                                                         | Obbligo                                                      |
|---------------------------------------------------------------------------------------------------|--------------------------------------------------------------|
| Visura camerale aggiornata                                                                        | Obbligatorio                                                 |
| Codice Fiscale + P.IVA                                                                            | Obbligatorio                                                 |
| Ultimi 2 bilanci depositati (per indicatori di stabilità)                                         | Obbligatorio                                                 |
| DURC valido                                                                                       | Obbligatorio                                                 |
| Visura del Casellario Giudiziale dell'amministratore (autocertificazione 231)                     | Obbligatorio                                                 |
| Iscrizione Albo Gestori Ambientali (se trasportatore/smaltitore rifiuti)                          | Obbligatorio se applicabile                                  |
| Certificazioni ISO valide (9001, 27001, 22301, 13485, 27701, 14001 — secondo natura del servizio) | Verificate; ISO 27001 OBBLIGATORIA per fornitori ICT critici |
| DPA (Data Processing Agreement) ex art. 28 GDPR                                                   | Obbligatorio se trattamento dati personali                   |
| Marcatura CE / certificazioni IVDR per IVD                                                        | Obbligatorio se IVD                                          |
| 8 clausole NIS2 contrattuali (cfr. PRO070 §8)                                                     | Obbligatorio per fornitori ICT critici                       |
| Cyber Insurance del fornitore                                                                     | Verificata se ICT critico                                    |
| Politica anti-corruzione + Modello 231 (se SpA/SpA-equivalente)                                   | Verificata per fornitori a spesa elevata                     |
| Codice Etico del fornitore                                                                        | Verificato                                                   |
| Risk-based questionnaire ESG                                                                      | Obbligatorio (introdotto rev 01)                             |

## 4.2 Documentazione richiesta — fornitori RILEVANTI/STANDARD

Documentazione semplificata: visura camerale, P.IVA, DURC, eventuali certificazioni di qualità del prodotto/servizio. DPA solo se trattamento dati personali.

## 4.3 Iter di qualifica

| Step | Attività                                                                                               | Owner                                                                                                | Output                                       |
|------|--------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------|----------------------------------------------|
| 1    | Identificazione del fabbisogno + classificazione preliminare di criticità (Critico/Rilevante/Standard) | Funzione richiedente + Procurement                                                                   | Richiesta di qualifica                       |
| 2    | Raccolta documentazione (cfr. §4.1 o §4.2)                                                             | Procurement                                                                                          | Fascicolo fornitore                          |
| 3    | Verifica documentale + risk assessment specifico (per Critici)                                         | Procurement + RSGI + IT Manager (per ICT)                                                            | Esito qualifica + classificazione definitiva |
| 4    | Approvazione formale                                                                                   | Per Critici: AD + RSGI; per Rilevanti: Procurement + Funzione richiedente; per Standard: Procurement | Decisione formalizzata                       |
| 5    | Iscrizione nell'Albo Fornitori (MOD040)                                                                | Procurement                                                                                          | Fornitore qualificato                        |
| 6    | Per Critici ICT: aggiornamento MOD182 (Inventario Fornitori ICT) e applicazione 8 clausole NIS2        | IT Manager + RSGI                                                                                    | Fornitore in MOD182 con clausole             |
| 7    | Stipulazione contratto + DPA + eventuali addendum                                                      | Procurement + Legale + DPO                                                                           | Contratto firmato                            |

## 5. Audit dei fornitori critici (formalizzato in rev 01)

### 5.1 Cadenza

| Tipo fornitore Critico                                                         | Cadenza audit                                                    | Modalità                                                                                          |
|--------------------------------------------------------------------------------|------------------------------------------------------------------|---------------------------------------------------------------------------------------------------|
| Fornitore ICT critico (LIS, RIS/PACS, datacenter, MSSP, conservatore digitale) | Audit ogni 24-36 mesi (rotazione triennale → ~30%/anno)          | Audit on-site o documentale strutturato; richiesta SOC 2 Type II o ISO 27001 Surveillance Reports |
| Fornitore IVD critico                                                          | Audit ogni 24 mesi                                               | Audit on-site (mass market vendor — review report di sorveglianza CE)                             |
| Smaltitore rifiuti pericolosi                                                  | Audit ogni 24 mesi + verifica Albo Gestori al 100%               | Verifica iscrizione + audit trasporti + esito Albo                                                |
| Studio Legale / DPO / OdV esterno                                              | Verifica annuale di affidabilità + nessun conflitto di interesse | Riesame contrattuale + dichiarazione annuale                                                      |
| Altri fornitori critici                                                        | Riesame annuale + audit on-event (su trigger di rischio)         | Documentale o on-site su decisione RSGI                                                           |

### 5.2 Trigger di audit straordinari

Indipendentemente dalla cadenza ordinaria, audit straordinari sono attivati quando:

- (a) il fornitore è oggetto di incidente di sicurezza (cyber-incident, data breach, violazione SLA);
- (b) il fornitore non rinnova certificazioni rilevanti (ISO 27001, ISO 13485, ecc.);
- (c) emergono criticità da sorveglianza giornaliera (degrado SLA, qualità dei prodotti, contestazioni);
- (d) cambia sostanzialmente il perimetro di servizio (es. nuovo data center, nuova sub-fornitura, nuovi sub-responsabili);
- (e) cambiano le condizioni di mercato o regolatorie (es. nuove norme ESG, AI, NIS2).

### 5.3 Output dell'audit

Ogni audit produce un verbale strutturato che include: scope, partecipanti, evidenze raccolte, NC rilevate, raccomandazioni, CAPA con scadenze, decisione di mantenimento/sospensione/dequalifica del fornitore. Il verbale è firmato dal team auditor (RSGI + Procurement + eventuale auditor esterno) e — se si rilevano NC che impattano operativamente — è comunicato all'Alta Direzione.

## 6. Valutazione periodica continuativa

Indipendentemente dall'audit formale, ogni fornitore è oggetto di valutazione periodica continuativa con i seguenti parametri (popolati su MOD042):

| Parametro                                                    | Frequenza    | Soglia critica                                     |
|--------------------------------------------------------------|--------------|----------------------------------------------------|
| Conformità dei prodotti/servizi (NC sui beni o sul servizio) | Continuativo | ≥ 3 NC in 12 mesi → riesame qualifica              |
| Tempi di consegna / SLA                                      | Continuativo | Ritardi > 10% delle consegne / Mese → riesame      |
| Qualità della comunicazione                                  | Continuativo | Subjective — owner di funzione segnala             |
| Gestione delle non conformità del fornitore                  | Per evento   | Mancata risposta a NC > 30 gg → escalation         |
| Sostenibilità ESG (per Critici)                              | Annuale      | Score < 60% → piano di miglioramento o dequalifica |
| Posizione finanziaria (DURC, segnalazioni protesti)          | Annuale      | DURC negativo → blocco pagamenti                   |
| Rinnovo certificazioni                                       | Annuale      | Mancato rinnovo → riesame qualifica                |

## 7. Decisioni post-valutazione / post-audit

| Esito                    | Conseguenza                                                                                      |
|--------------------------|--------------------------------------------------------------------------------------------------|
| Qualifica MANTENUTA      | Fornitore prosegue nel rapporto contrattuale ordinario                                           |
| Qualifica CON CONDIZIONI | Fornitore prosegue con piano di rientro su NC rilevate (CAPA con scadenze)                       |
| Qualifica SOSPESA        | Sospensione di nuovi ordini in attesa di rientro CAPA — durata max 6 mesi                        |
| Qualifica DEQUALIFICATA  | Cessazione del rapporto entro tempi compatibili con BCP/exit plan; ricerca fornitore alternativo |

## 8. KPI di processo

| KPI | Target |
|-----|--------|
|-----|--------|

|                                                               |                            |
|---------------------------------------------------------------|----------------------------|
| % fornitori critici con audit nei tempi (rotazione triennale) | 100%                       |
| % fornitori critici con clausole NIS2 contrattuali            | 100% (obiettivo 1/10/2026) |
| % fornitori ICT critici con ISO 27001 valida                  | ≥ 80%                      |
| % fornitori critici con DPA in vigore (su trattamento dati)   | 100%                       |
| Tempo medio chiusura NC su fornitori critici                  | ≤ 90 giorni                |
| % fornitori critici con score ESG ≥ 60%                       | ≥ 50% al 2027              |
| Numero dequalifiche/anno                                      | Tracciato + analisi cause  |

## 9. Storico delle revisioni

| Rev. | Data       | Descrizione                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           | Redatto            | Approvato |
|------|------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------|-----------|
| 00   | 15/04/2026 | Prima emissione della Procedura di Qualificazione e Valutazione dei Fornitori.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        | Procurement + RSGI | AD        |
| 01   | 30/04/2026 | Estensione rev 01: introdotto il concetto di FORNITORE CRITICO con requisiti di qualifica rinforzati e 8 criteri di criticità (servizi clinici essenziali, accesso a dati personali, accesso privilegiato, indisponibilità impattante, notifiche obbligatorie ACN/Garante, consulenza specialistica con dati riservati, IVD/dispositivi medici, spesa > 5%); formalizzato calendario di AUDIT periodico (24-36 mesi per ICT critici, 24 mesi per IVD e smaltitori, annuale per Studio Legale/DPO/OdV esterni); trigger di audit straordinari (5 casi); 8 clausole NIS2 obbligatorie per fornitori ICT critici (cfr. PRO070 §8); risk-based ESG questionnaire; coordinamento con MOD182 (Inventario Fornitori ICT) e MOD195 (Valutazione service Lab). | Procurement + RSGI | AD        |